



ZAP by Checkmarx Scanning Report

Security assessment of React application running on localhost

Generated on Fri, 24 Apr 2026 05:36:04

ZAP Version: 2.17.0

ZAP by Checkmarx



High Medium Low Informational

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	6
Low	3

Informational

4

Insights

Level	Reason	Site	Description	Statistic
Medium	Exceeded High		Percentage of network failures	93 %
Low	Warning		ZAP errors logged - see the zap.log file for details	7
Low	Warning		ZAP warnings logged - see the zap.log file for details	1,012
Info	Informational	http://code.ionicframework.com	Percentage of responses with status code 3xx	100 %
Info	Informational	http://code.ionicframework.com	Percentage of endpoints with method GET	100 %
Info	Informational	http://code.ionicframework.com	Count of total endpoints	1
Info	Informational	http://code.ionicframework.com	Percentage of slow responses	100 %
Info	Informational	http://demo.productionready.io	Percentage of responses with status code 4xx	100 %
Info	Informational	http://demo.productionready.io	Percentage of endpoints with content type text/html	100 %
Info	Informational	http://demo.productionready.io	Percentage of endpoints with method GET	100 %
Info	Informational	http://demo.productionready.io	Count of total endpoints	1
Info	Informational	http://demo.productionready.io	Percentage of slow responses	100 %
Info	Informational	http://localhost:4100	Percentage of responses with status code 1xx	10 %
Info	Informational	http://localhost:4100	Percentage of responses with status code 2xx	44 %

Info	Informational	http://localhost:4100	Percentage of responses with status code 3xx	12 %
Info	Informational	http://localhost:4100	Percentage of responses with status code 4xx	32 %
Info	Informational	http://localhost:4100	Percentage of responses with status code 5xx	2 %
Info	Informational	http://localhost:4100	Percentage of endpoints with content type application/javascript	7 %
Info	Informational	http://localhost:4100	Percentage of endpoints with content type application/json	7 %
Info	Informational	http://localhost:4100	Percentage of endpoints with content type image/x-icon	7 %
Info	Informational	http://localhost:4100	Percentage of endpoints with content type text/event-stream	7 %
Info	Informational	http://localhost:4100	Percentage of endpoints with content type text/html	23 %
Info	Informational	http://localhost:4100	Percentage of endpoints with content type text/plain	7 %
Info	Informational	http://localhost:4100	Percentage of endpoints with method GET	92 %
Info	Informational	http://localhost:4100	Percentage of endpoints with method POST	7 %
Info	Informational	http://localhost:4100	Count of total endpoints	13
Info	Informational	http://localhost:4100	Percentage of slow responses	2 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %
Info	Informational	https://code.ionicframework.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://code.ionicframework.com	Percentage of endpoints with content type text/css	100 %

Info	Informational	https://code.ionicframework.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://code.ionicframework.com	Count of total endpoints	1
Info	Informational	https://code.ionicframework.com	Percentage of slow responses	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Count of total endpoints	1
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of slow responses	100 %
Info	Informational	https://localhost:4100	Percentage of endpoints with method GET	100 %
Info	Informational	https://localhost:4100	Count of total endpoints	1

Alerts

Name	Risk Level	Number of Instances
CSP:..Failure..to..Define..Directive..with..No..Fallback	Medium	2
Content..Security..Policy..(CSP)..Header..Not..Set	Medium	2
Cross-Domain..Misconfiguration	Medium	4
HTTP..Only..Site	Medium	1
Missing..Anti-clickjacking..Header	Medium	1
Sub..Resource..Integrity..Attribute..Missing	Medium	1
Server..Leaks..Information..via.."X-Powered-By"..HTTP..Response..Header..Field(s)	Low	5

Timestamp Disclosure - Unix	Low	2
X-Content-Type-Options Header Missing	Low	4
Information Disclosure - Suspicious Comments	Informational	13
Modern Web Application	Informational	1
Re-examine Cache-control Directives	Informational	1
Retrieved from Cache	Informational	2

Passing Rules

Name	Rule Type	Threshold	Strength
Directory Browsing	Active	MEDIUM	MEDIUM
Path Traversal	Active	MEDIUM	MEDIUM
Remote File Inclusion	Active	MEDIUM	MEDIUM
XSLT Injection	Active	MEDIUM	MEDIUM
Server Side Code Injection	Active	MEDIUM	MEDIUM
XPath Injection	Active	MEDIUM	MEDIUM
Remote OS Command Injection	Active	MEDIUM	MEDIUM
XML External Entity Attack	Active	MEDIUM	MEDIUM
Generic Padding Oracle	Active	MEDIUM	MEDIUM
SOAP Action Spoofing	Active	MEDIUM	MEDIUM
SOAP XML Injection	Active	MEDIUM	MEDIUM
Heartbleed OpenSSL Vulnerability	Active	MEDIUM	MEDIUM
Buffer Overflow	Active	MEDIUM	MEDIUM
Source Code Disclosure - CVE-2012-1823	Active	MEDIUM	MEDIUM
Format String Error	Active	MEDIUM	MEDIUM
Server Side Template Injection	Active	MEDIUM	MEDIUM

Remote Code Execution - CVE-2012-1823	Active	MEDIUM	MEDIUM
Cloud Metadata Potentially Exposed	Active	MEDIUM	MEDIUM
External Redirect	Active	MEDIUM	MEDIUM
Remote OS Command Injection (Time Based)	Active	MEDIUM	MEDIUM
Server Side Template Injection (Blind)	Active	MEDIUM	MEDIUM
Source Code Disclosure - /WEB-INF Folder	Active	MEDIUM	MEDIUM
HTTPS Content Available via HTTP	Active	MEDIUM	MEDIUM
Remote Code Execution - Shell Shock	Active	MEDIUM	MEDIUM
CRLF Injection	Active	MEDIUM	MEDIUM
Parameter Tampering	Active	MEDIUM	MEDIUM
Server Side Include	Active	MEDIUM	MEDIUM
Swagger UI Secret & Vulnerability Detector	Active	MEDIUM	MEDIUM
GET for POST	Active	MEDIUM	MEDIUM
Cross Site Scripting (Reflected)	Active	MEDIUM	MEDIUM
Cross Site Scripting (Persistent)	Active	MEDIUM	MEDIUM
Script Active Scan Rules	Active	MEDIUM	MEDIUM
Cross Site Scripting (Persistent) - Prime	Active	MEDIUM	MEDIUM
Cross Site Scripting (Persistent) - Spider	Active	MEDIUM	MEDIUM
SQL Injection	Active	MEDIUM	MEDIUM
SQL Injection - MySQL (Time Based)	Active	MEDIUM	MEDIUM
SQL Injection - Hypersonic SQL (Time Based)	Active	MEDIUM	MEDIUM
SQL Injection - Oracle (Time Based)	Active	MEDIUM	MEDIUM
SQL Injection - PostgreSQL (Time Based)	Active	MEDIUM	MEDIUM
Cross Site Scripting (DOM Based)	Active	MEDIUM	MEDIUM
SQL Injection - MsSQL (Time Based)	Active	MEDIUM	MEDIUM

ELMAH..Information..Leak	Active	MEDIUM	MEDIUM
Trace..axd..Information..Leak	Active	MEDIUM	MEDIUM
..htaccess..Information..Leak	Active	MEDIUM	MEDIUM
..env..Information..Leak	Active	MEDIUM	MEDIUM
Hidden..File..Finder	Active	MEDIUM	MEDIUM
Spring..Actuator..Information..Leak	Active	MEDIUM	MEDIUM
Log4Shell	Active	MEDIUM	MEDIUM
Exponential..Entity..Expansion...(Billion..Laughs Attack)	Active	MEDIUM	MEDIUM
Spring4Shell	Active	MEDIUM	MEDIUM
Remote..Code..Execution...(React2Shell)	Active	MEDIUM	MEDIUM
User..Agent..Fuzzer	Active	MEDIUM	MEDIUM
Session..Management..Response..Identified	Passive	MEDIUM	-
Verification..Request..Identified	Passive	MEDIUM	-
Private..IP..Disclosure	Passive	MEDIUM	-
Session..ID..in..URL..Rewrite	Passive	MEDIUM	-
Script..Served..From..Malicious..Domain...(polyfill)	Passive	MEDIUM	-
ZAP..is..Out..of..Date	Passive	MEDIUM	-
Insecure..JSF..ViewState	Passive	MEDIUM	-
Java..Serialization..Object	Passive	MEDIUM	-
Vulnerable..JS..Library...(Powered..by..Retire..js)	Passive	MEDIUM	-
In..Page..Banner..Information..Leak	Passive	MEDIUM	-
Charset..Mismatch	Passive	MEDIUM	-
Cookie..No..HttpOnly..Flag	Passive	MEDIUM	-
Cookie..Without..Secure..Flag	Passive	MEDIUM	-
Cross-Domain..JavaScript..Source..File..Inclusion	Passive	MEDIUM	-

Content-Type-Header-Missing	Passive	MEDIUM	-
Application-Error-Disclosure	Passive	MEDIUM	-
Information-Disclosure--Debug-Error-Messages	Passive	MEDIUM	-
Information-Disclosure--Sensitive-Information-in-URL	Passive	MEDIUM	-
Information-Disclosure--Sensitive-Information-in-HTTP-Referrer-Header	Passive	MEDIUM	-
Off-site-Redirect	Passive	MEDIUM	-
Cookie-Poisoning	Passive	MEDIUM	-
User-Controllable-Charset	Passive	MEDIUM	-
WSDL-File-Detection	Passive	MEDIUM	-
User-Controllable-HTML-Element-Attribute (Potential-XSS)	Passive	MEDIUM	-
Loosely-Scoped-Cookie	Passive	MEDIUM	-
Viewstate	Passive	MEDIUM	-
Directory-Browsing	Passive	MEDIUM	-
Heartbleed-OpenSSL-Vulnerability-(Indicative)	Passive	MEDIUM	-
Strict-Transport-Security-Header	Passive	MEDIUM	-
HTTP-Server-Response-Header	Passive	MEDIUM	-
X-Backend-Server-Header-Information-Leak	Passive	MEDIUM	-
Secure-Pages-Include-Mixed-Content	Passive	MEDIUM	-
HTTP-to-HTTPS-Insecure-Transition-in-Form-Post	Passive	MEDIUM	-
HTTPS-to-HTTP-Insecure-Transition-in-Form-Post	Passive	MEDIUM	-
User-Controllable-JavaScript-Event-(XSS)	Passive	MEDIUM	-
Big-Redirect-Detected-(Potential-Sensitive-Information-Leak)	Passive	MEDIUM	-
X-ChromeLogger-Data-(XCOLD)-Header-Information-Leak	Passive	MEDIUM	-

Cookie.without.SameSite.Attribute	Passive	MEDIUM	-
X-Debug-Token.Information.Leak	Passive	MEDIUM	-
Username.Hash.Found	Passive	MEDIUM	-
X-AspNet-Version.Response.Header	Passive	MEDIUM	-
PII.Disclosure	Passive	MEDIUM	-
Script.Passive.Scan.Rules	Passive	MEDIUM	-
Stats.Passive.Scan.Rule	Passive	MEDIUM	-
Absence.of.Anti-CSRF.Tokens	Passive	MEDIUM	-
Hash.Disclosure	Passive	MEDIUM	-
Weak.Authentication.Method	Passive	MEDIUM	-
Reverse.Tabnabbing	Passive	MEDIUM	-
Authentication.Request.Identified	Passive	MEDIUM	-

Sites

https://localhost:4100

HTTP Response Code	Number of Responses
--------------------	---------------------

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values
----------------	------	-------	------------	----------

https://firefox.settings.services.mozilla.com

HTTP Response Code	Number of Responses
200.OK	2

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values
----------------	------	-------	------------	----------

https://code.ionicframework.com

HTTP Response Code	Number of Responses
200 OK	2

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values
----------------	------	-------	------------	----------

http://demo.productionready.io

HTTP Response Code	Number of Responses
403 Forbidden	5

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values
----------------	------	-------	------------	----------

http://code.ionicframework.com

HTTP Response Code	Number of Responses
301 Moved Permanently	5

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values
----------------	------	-------	------------	----------

http://localhost:4100

HTTP Response Code	Number of Responses
304..Not..Modified	6
404..Not..Found	16
504..Gateway..Timeout	1
200..OK	22
101..Switching..Protocols	5

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values
----------------	------	-------	------------	----------

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://localhost:4100/robots.txt
No de Na me	http://localhost:4100/robots.txt
Me th od	GET

Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Show / hide Request and Response	
Request Header - size : 239 bytes.	
Requ	

es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
14
9
by
te
s.

URL <http://localhost:4100/sitemap.xml>

No
de
Na
me <http://localhost:4100/sitemap.xml>

Me
th
od GET

Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Show / hide Request and Response	
Request Header - size: 240 bytes.	
Requ	

es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
15
0
by
te
s.

Instances2

SolutionEnsure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.

Reference<https://www.w3.org/TR/CSP/>
<https://caniuse.com/#search=content+security+policy>
<https://content-security-policy.com/>
<https://github.com/HtmlUnit/htmlunit-csp>
<https://web.dev/articles/csp#resource-options>

Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC CWE_693 OWASP_2017_A06 OWASP_2025_A02 POLICY_DEV_STD =
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page – covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://demo.productionready.io/main.css
No de Na me	http://demo.productionready.io/main.css
Me th od	GET
Pa ra me te r	
At ta ck	
Ev id	

en
ce

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
31
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
71
9
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
33
6
by
te
s.

URL <http://localhost:4100/>

No
de
Na
me <http://localhost:4100/>

Me
th
od GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by

te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8
by
te
s.

Instances2

SolutionEnsure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Reference<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://www.w3.org/TR/CSP/>
<https://w3c.github.io/webappsec-csp/>
<https://web.dev/articles/csp>
<https://caniuse.com/#feat=contentsecuritypolicy>
<https://content-security-policy.com/>

Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC CWE-693 OWASP_2017_A06 OWASP_2025_A02
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	http://localhost:4100/sockjs-node/367/glhdnawg/eventsource
No de Na me	http://localhost:4100/sockjs-node/367/glhdnawg/eventsource
Me th od	GET
Pa ra me te r	
At ta ck	
Ev id en ce	Access-Control-Allow-Origin: *
Ot he r	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs,

In
fo

however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
44
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad

er
-
si
ze
:
25
9
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
0
by
te
s.

URLhttp://localhost:4100/sockjs-node/info?t=1776989258047

No
de
Na
mehttp://localhost:4100/sockjs-node/info (t)

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ceAccess-Control-Allow-Origin: *

Ot
he
rThe CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit

In
fo

arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
36
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He

ad-
er-
si-
ze-
:
29
3
by-
te-
s.

Re-
sp-
on-
se-
Bo-
dy-
:
si-
ze-
:
79
by-
te-
s.

URLhttps://code.ionicframework.com/ionicons/2.0.1/css/ionicons.min.css

No-
de-
Na-
mehttps://code.ionicframework.com/ionicons/2.0.1/css/ionicons.min.css

Me-
th-
odGET

Pa-
ra-
me-
te-
r

At-
ta-
ck

Ev-
id-
en-
ceAccess-Control-Allow-Origin: *

Ot-
heThe CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated

r
In
fo

APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
41
8
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se

Header - size : 1,295 bytes.

Response Body - size : 51,284 bytes.

URLhttps://firefox.settings.services.mozilla.com/v1/buckets/monitor/collections/changes/changeset?collection=mfcdm-origins-list&bucket=main&_expected=0

Node Namehttps://firefox.settings.services.mozilla.com/v1/buckets/monitor/collections/changes/changeset (_expected,bucket,collection)

MethodGET

Parameter

Attack

Event IDaccess-control-allow-origin: *

en
ce

Ot
he
r
In
fo

The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
37
4
by
te
s.

Request Body - size : 0 bytes.

Response Header - size : 835 bytes.

Response Body - size : 244 bytes.

Instances4

SolutionEnsure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).
Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
Tags	OWASP_2021_A01 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2025_A01 OWASP_2017_A05 CWE-264
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	HTTP Only Site
Description	The site is only served under HTTP and not HTTPS.
URL	http://localhost:4100/
No de Na me	https://localhost:4100/
Me th od	GET
Pa ra me te r	
At ta ck	
Ev id en ce	

Ot
he
r
In
fo

Failed to connect.

ZAP attempted to connect via: https://localhost:4100/

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
23
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on

se
He
ad
er
-
si
ze
:
14
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
0
by
te
s.

Instances	1
Solution	Configure your web or application server to use SSL (https).
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html https://letsencrypt.org/
Tags	OWASP_2025_A04 OWASP_2021_A05 POLICY_QA_FULL = POLICY_PENTEST = OWASP_2017_A06 WSTG-v42-CRYP-03 CWE-311
CWE Id	311
WASC Id	4
Plugin Id	10106

MediumMissing Anti-clickjacking Header

DescriptionThe response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors'

directive or X-Frame-Options.

URLhttp://localhost:4100/

No
de
Na
mehttp://localhost:4100/

Me
th
odGET

Pa
ra
me
te
rx-frame-options

At
ta
ck

Ev
id
en
ce

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es

t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8

by te s.	
Instances	1
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.
	If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = CWE-1021 SYSTEMIC WSTG-v42-CLNT-09 OWASP_2017_A06 OWASP_2025_A02
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://localhost:4100/
No de Na me	http://localhost:4100/
Me th od	GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce

```
<link href="//fonts.googleapis.com/css?
family=Titillium+Web:700|Source+Serif+Pro:400,700|Merriweather+Sans:4
00,700|Source+Sans+Pro:400,300,600,700,300italic,400italic,600italic,
700italic" rel="stylesheet" type="text/css">
```

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu

es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8
by
te
s.

Instances1

SolutionProvide a valid integrity attribute to the tag.

Referencehttps://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

TagsCWE-345
OWASP_2021_A05
POLICY_QA_STD =
POLICY_PENTEST =

	SYSTEMIC OWASP_2017_A06 OWASP_2025_A02 POLICY_DEV_STD =
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://localhost:4100/
No de Na me	http://localhost:4100/
Me th od	GET
Pa ra me te r	
At ta ck	
Ev id en ce	X-Powered-By: Express
Ot he r	

In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er

-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8
by
te
s.

URLhttp://localhost:4100/favicon.ico

No
de
Na
mehttp://localhost:4100/favicon.ico

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ceX-Powered-By: Express

Ot
he

r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
27
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad

er
-
si
ze
:
33
0
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
24
,8
38
by
te
s.

URLhttp://localhost:4100/robots.txt

No
de
Na
mehttp://localhost:4100/robots.txt

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ceX-Powered-By: Express

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
23
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on

se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
14
9
by
te
s.

URLhttp://localhost:4100/sitemap.xml

No
de
Na
mehttp://localhost:4100/sitemap.xml

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ceX-Powered-By: Express

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
24
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on

se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
15
0
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No
de
Na
me <http://localhost:4100/static/js/bundle.js>

Me
th
od GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce X-Powered-By: Express

Ot
he
r
In
fo

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
41
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on

se
He
ad
er
-
si
ze
:
20
4
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
0
by
te
s.

Instances	5
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Tags	OWASP_2021_A01 WSTG-v42-INFO-08 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2017_A03 OWASP_2025_A01 CWE-497
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:4100/sockjs-node/info?t=1776989261841
Node Name	http://localhost:4100/sockjs-node/info (t)
Method	GET
Parameter	
Attack	
Evidence	1526079679
Other Info	1526079679, which evaluates to: 2018-05-12 04:01:19.
Show / hide Request and Response	

Re
qu
es
t
He
ad
er
-
si
ze
:
36
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze

:
79
by
te
s.

URLhttp://localhost:4100/sockjs-node/info?t=1776989280051

No
de
Na
mehttp://localhost:4100/sockjs-node/info (t)

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce1532522468

Ot
he
r
In
fo1532522468, which evaluates to: 2018-07-25 17:41:08.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
36
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze

: 79 bytes.	
Instances	2
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
Tags	OWASP_2021_A01 POLICY_PENTEST = SYSTEMIC OWASP_2017_A03 OWASP_2025_A01 CWE-497
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:4100/
No de Na me	http://localhost:4100/
Me th od	GET
Pa ra me	x-content-type-options

te
r

At
ta
ck

Ev
id
en
ce

Ot
he
r
In
fo

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es
t

Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8
by
te
s.

URLhttp://localhost:4100/favicon.ico

No
de
Na
mehttp://localhost:4100/favicon.ico

Me
th
odGET

Pa
ra
me
te
r

x-content-type-options

At
ta
ck

Ev
id
en
ce

Ot
he
r
In
fo

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
27
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
33
0
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
24
,8
38
by
te
s.

URL <http://localhost:4100/sockjs-node/info?t=1776989258047>

No
de
Na
me <http://localhost:4100/sockjs-node/info> (t)

Me
th
od

GET

Pa
ra
me
te
r

x-content-type-options

At
ta
ck

Ev
id
en
ce

Ot
he
r
In
fo

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
36
4

by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
79
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No de Na me	http://localhost:4100/static/js/bundle.js
Me th od	GET
Pa ra me te r	x-content-type-options
At ta ck	
Ev id en ce	
Ot he r In fo	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Sh ow / hi de Re qu es t an d Re sp on se	
Re qu es t He ad er	

-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by

tes.	
Instances	4
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC CWE-693 OWASP_2017_A06 OWASP_2025_A02
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:4100/
No de Na me	http://localhost:4100/
Me th od	GET
Pa ra	

me
te
r

At
ta
ck

Ev
id
en
ce

r can be referenced from the HTML.

Ot
he
r
In
fo

The following pattern was used: \bFROM\b and was detected in likely comment: "<!--

Notice the use of in the tag above.

It will be replaced with the URL of the `public` folder during the build", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es

t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No
de
Na
me <http://localhost:4100/static/js/bundle.js>

Me
th
od GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce

get lost while the user is

Ot
he
r
In
fo

The following pattern was used: \bUSER\b and was detected 52 times, the first in likely comment: "// Safari 6.0 has a problem where timers will get lost while the user is", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu

es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

MethodGET

Parameter

Attack

Evidence

the `auth` for the username and password.

Other Info

The following pattern was used: \bUSERNAME\b and was detected in likely comment: "// Parse down the `auth` for the username and password.", see evidence field for the suspicious comment/snippet.

Show/Hide Request and Response

Request Header - size: 281 by

te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No de Na me	http://localhost:4100/static/js/bundle.js
Me th od	GET
Pa ra me te r	
At ta ck	
Ev id en ce	value The value to query. * @returns {strin
Ot he r In fo	The following pattern was used: \bQUERY\b and was detected 20 times, the first in likely comment: "/* * The base implementation of `getTag` without fallbacks for buggy environments. * * @private * @param {*} value The valu", see evidence field for the suspicious comment/snippet.
Sh ow / hi de Re qu es t an d Re sp on se	
Re qu	

es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46

7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce!*** ./node_modules/debug/src/browser.js ***!

Ot
he
r
In
foThe following pattern was used: \bDEBUG\b and was detected 37 times,
the first in likely comment:
"/*!*****!*\n
!*** ./node_modules/debug/src/browser.js ***!
*****", see evidence field for the suspicious
comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp

00
SE

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy

-
si
ze
:
2,
46
7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce/** * Select a color. * @param

The following pattern was used: \bSELECT\b and was detected 17 times, the first in likely comment: "/*

Ot
he
r
In
fo* Select a color.
* @param {String} namespace
* @return {Number}
* @api private
*/", see evidence field for the suspicious comment/snippet.

Sh
ow
/

hide
Request
and
Response

Request
Header-
size:
281
bytes.

Request
Body-
size:
0
bytes.

Response
Header-
size:
295
bytes.

te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce// See https://bugs.chromium.org/p/chro

Ot
he
r
In
foThe following pattern was used: \bBUGS\b and was detected 12 times,
the first in likely comment: "// See
https://bugs.chromium.org/p/chromium/issues/detail?id=465666", see
evidence field for the suspicious comment/snippet.

Show
/hide
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze

:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce// TODO remove in webpack 4

Ot
he
r
In
fo

The following pattern was used: \bTODO\b and was detected 192 times, the first in likely comment: "// TODO remove in webpack 4", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on

se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

Me
th
odGET

Pa
ra
me
te
r

At
ta
ck

Ev
id// XXX: file:// URIs and a

en
ce

Ot
he
r
In
fo

The following pattern was used: \bXXX\b and was detected 4 times, the first in likely comment: "// XXX: file:// URIs and absolute paths lead to unexpected behavior for", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No
de
Na
me <http://localhost:4100/static/js/bundle.js>

Me
th
od GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce

```
//inherit from previous dispose ca
```

Ot
he
r
In
fo

The following pattern was used: \bFROM\b and was detected 237 times, the first in likely comment: "//inherit from previous dispose call", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No
de
Na
me <http://localhost:4100/static/js/bundle.js>

Me
th
od GET

Pa
ra
me

te
r

At
ta
ck

Ev
id
en
ce

ent and will resume where it left off when ca

Ot
he
r
In
fo

The following pattern was used: \bWHERE\b and was detected 55 times, the first in likely comment: "// consistent and will resume where it left off when called again.", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu
es
t
Bo
dy

-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URL <http://localhost:4100/static/js/bundle.js>

No
de
Na
me <http://localhost:4100/static/js/bundle.js>

Me
th
od GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce

ere appears to be a bug in Internet Explore

Ot
he
r
In
fo

The following pattern was used: \bBUG\b and was detected 19 times, the first in likely comment: "// Unfortunately there appears to be a bug in Internet Explorer 10 Mobile (and", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by
te
s.

Re
qu

es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

URLhttp://localhost:4100/static/js/bundle.js

No
de
Na
mehttp://localhost:4100/static/js/bundle.js

Me
th
od

GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce

les to require them later by the module syste

Ot
he
r
In
fo

The following pattern was used: \bLATER\b and was detected 30 times, the first in likely comment: "// Store self accepted outdated modules to require them later by the module system", see evidence field for the suspicious comment/snippet.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
28
1
by

te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
29
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
2,
46
7,
21
6
by
te
s.

Instances13

Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
Tags	OWASP_2021_A01 POLICY_PENTEST = CWE-615 WSTG-v42-INFO-05 OWASP_2017_A03 OWASP_2025_A01
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:4100/
Node Name	http://localhost:4100/
Method	GET
Parameter	
Attack	

Ev
id
en
ce

<script type="text/javascript" src="/static/js/bundle.js"></script>

Ot
he
r
In
fo

No links have been found while there are scripts, which is an indication that this is a modern web application.

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by

te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
27
6
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
60
8
by
te
s.

Instances1

SolutionThis is an informational alert and so no changes are required.

Reference

Tags

[OWASP_2021_A05](#)
[POLICY_QA_STD](#) =
[POLICY_PENTEST](#) =
[SYSTEMIC](#)
[OWASP_2017_A06](#)
[OWASP_2025_A02](#)
[POLICY_DEV_STD](#) =

CWE Id

WASC Id

Plugin Id10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://firefox.settings.services.mozilla.com/v1/buckets/monitor/collections/changes/changeset?collection=mfcdm-origins-list&bucket=main&_expected=0
No de Na me	https://firefox.settings.services.mozilla.com/v1/buckets/monitor/collections/changes/changeset (_expected,bucket,collection)
Me th od	GET
Pa ra me te r	cache-control
At ta ck	
Ev id en ce	max-age=60
Ot he r In fo	
Sh ow / hi de Re qu es	

t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
37
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
83
5
by
te
s.

Response Body - size: 244 bytes.

Instances1

SolutionFor secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

Referencehttps://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
<https://grayduck.mn/2021/09/13/cache-control-recommendations/>

TagsOWASP_2025_A07
CWE-525
POLICY_PENTEST =
OWASP_2021_A07
SYSTEMIC
WSTG-v42-ATHN-06
OWASP_2017_A02

CWE Id525

WASC Id13

Plugin Id10015

InformationalRetrieved from Cache

DescriptionThe content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

URL		https://code.ionicframework.com/ionicons/2.0.1/css/ionicons.min.css
No de Na me		https://code.ionicframework.com/ionicons/2.0.1/css/ionicons.min.css
Me th od	GET	
Pa ra me te r		
At ta ck		
Ev id en ce	HIT	
Ot he r In fo		
Sh ow / hi de Re qu es t and Re sp on se		
Re qu es t		

Header-
size:
418
bytes.

Request
Body-
size:
0
bytes.

Response
Header-
size:
1,295
bytes.

Response
Body-
size:
51,284

by te s.	
URL	https://firefox.settings.services.mozilla.com/v1/buckets/monitor/collections/changes/changeset?collection=mfcdm-origins-list&bucket=main&_expected=0
No de Na me	https://firefox.settings.services.mozilla.com/v1/buckets/monitor/collections/changes/changeset (_expected,bucket,collection)
Me th od	GET
Pa ra me te r	
At ta ck	
Ev id en ce	HIT
Ot he r In fo	
Sh ow / hi de Re qu es t an d Re sp on se	

Re
qu
es
t
He
ad
er
-
si
ze
:
37
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
83
5
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze

:
24
4
by
te
s.

Instances2

Solution

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

Reference

<https://datatracker.ietf.org/doc/html/rfc7234>
<https://datatracker.ietf.org/doc/html/rfc7231>
<https://www.rfc-editor.org/rfc/rfc9110.html>

Tags

OWASP_2025_A07
CWE-525
POLICY_PENTEST =
OWASP_2021_A07
SYSTEMIC
WSTG-v42-ATHN-06
OWASP_2017_A02

CWE Id

525

WASC Id

Plugin Id

10050

Report by ZAP